

AI-Generated Emails in Phishing Attacks: Effectiveness and Defense Strategies

Kalpitha Sheshachalam Naidu

Master of Science in Cybersecurity and Networks

University of New Haven

West Haven, Connecticut, USA

Abstract

Phishing attacks remain one of the most prevalent cybersecurity threats, with artificial intelligence (AI) tools fundamentally transforming the threat landscape. This literature review examines recent research on AI-generated phishing emails, comparing their effectiveness to human-crafted attempts and evaluating current detection methods. Analysis of key studies reveals that AI-generated phishing emails achieve click rates of 54% compared to 12% for non-personalized control emails, performing on par with human experts. Machine learning models, particularly LSTM networks, show promise with 87% detection accuracy, yet significant gaps remain in testing modern AI models (GPT-4, Claude, Gemini), real-world deployment, dataset diversity, and psychological understanding of victim behavior. This review identifies critical research gaps and proposes future directions for developing comprehensive defense strategies combining technical detection with human-centered awareness training.

Keywords: Phishing, AI-generated emails, cybersecurity, machine learning detection, GPT, LSTM, social engineering

1. Introduction

Phishing attacks exploit human psychology and trust to compromise sensitive information, making them the most pervasive cybersecurity threat. Traditionally, phishing emails were identifiable through grammatical errors, awkward phrasing, and generic content. However, the emergence of large language models (LLMs) like ChatGPT, GPT-4, Claude, and Gemini has fundamentally changed this landscape.

AI-powered language models can generate grammatically perfect, contextually appropriate, and highly personalized phishing emails at scale. Unlike human attackers who must manually craft emails, AI systems can generate thousands of sophisticated attempts instantly, each tailored to specific recipients. This capability represents a paradigm shift that challenges both technical defenses and human judgment.

This literature review addresses two fundamental research questions:

RQ1: How effective are AI-generated phishing emails compared to human-crafted ones?

RQ2: Which defense methods or awareness strategies can best detect and resist AI-generated phishing?

2. Background

2.1 Traditional Phishing

Phishing is a social engineering attack where adversaries masquerade as trustworthy entities to deceive victims into divulging sensitive information. Traditional phishing emails exhibit characteristic features: spelling and grammatical errors, generic greetings, urgent language, suspicious URLs, and

requests for sensitive information. Security awareness training has focused on teaching users to recognize these red flags.

2.2 The Rise of AI Language Models

Large language models like GPT-3, GPT-4, Claude, and Gemini have demonstrated unprecedented capabilities in understanding and generating human-like text. These models are trained on vast corpora of internet text, learning language patterns across countless contexts and styles. They can generate grammatically perfect, stylistically appropriate, and contextually coherent text, making them powerful tools for both legitimate and malicious purposes.

2.3 AI-Generated Phishing

AI-generated phishing overcomes traditional limitations:

- Perfect Grammar: Eliminates spelling and grammatical errors
- Contextual Relevance: Generates content appropriate to specific scenarios
- Personalization at Scale: Creates thousands of personalized emails instantly
- Adaptive Content: Adjusts tone and persuasive techniques based on intended effect

The barrier to entry for sophisticated phishing has dramatically decreased, as adversaries need only access to an LLM and basic prompting skills.

3. Current State of Knowledge

3.1 Effectiveness of AI-Generated Phishing

Heiding et al. (2024) conducted the most comprehensive evaluation of AI-generated phishing on human subjects. The study recruited 101 participants and tested four email types:

1. Control Group (arbitrary phishing): 12% click-through rate
2. Human Expert emails: 54% click-through rate
3. Fully AI-automated emails (Claude 3.5 Sonnet): 54% click-through rate
4. AI with human-in-the-loop: 56% click-through rate

Key Findings:

- AI-automated attacks performed on par with human experts, achieving 350% better results than control emails
- AI-gathered information was accurate in 88% of cases, with only 4% producing incorrect profiles
- Participants mentioned personalization as a trust factor in 40% of AI email responses versus 0% for control emails
- The AI tool reduced information gathering time by 92% compared to manual methods

The study demonstrated that frontier AI models no longer require human-in-the-loop intervention to achieve expert-level phishing effectiveness, marking significant improvement from 2023 studies where AI needed human assistance.

3.2 Detection Methods

Alharthi et al. (2023/2024) investigated machine learning approaches for detecting AI-generated phishing emails using multiple detection models:

1. Traditional Spam Filters: 43% accuracy - essentially chance-level performance
2. Random Forest Classifier: 71% accuracy
3. LSTM Neural Networks: 87% accuracy - highest performance

Detection Features: LSTM models could identify subtle AI patterns including:

- Unnaturally consistent grammar and punctuation
- Overly formal language structures
- Subtle repetitive patterns in sentence construction
- Lack of natural linguistic variation typical in human writing

Heiding et al. (2024) - AI Detection Capabilities: The study also tested AI models for detecting phishing:

- Claude 3.5 Sonnet achieved 97.25% detection rate with 0% false positives
- GPT-4o showed lower but still promising performance
- When primed for suspicion (specifically asked to detect suspicious emails), Claude detected 100% of phishing attempts while correctly classifying all legitimate emails

3.3 Psychological Mechanisms

Research indicates humans process emails through rapid, heuristic-based evaluation relying on superficial trust signals. Professional appearance, proper grammar, and contextual appropriateness serve as powerful trust indicators. AI-generated emails excel at mimicking these signals, overwhelming careful scrutiny.

Trust Factors Identified:

- Presentation: Professional formatting and grammar
- Personalization: Relevant, tailored content (40% mentioned for AI emails)
- Call to Action: Attractive, legitimate-seeming requests
- Sender Authenticity: Perceived trustworthy sender

4. Gaps in Literature

4.1 Limited AI Model Coverage

Gap: Most research focuses on GPT-3 or early Claude versions. Advanced models like GPT-4, Claude 3.5, and Gemini remain largely untested.

Implications: Heiding et al. demonstrated that models trained on GPT-3 emails showed only 62% accuracy on GPT-4 content—dramatic performance degradation highlighting rapid obsolescence. Newer models likely generate even more convincing phishing content.

Research Need: Comprehensive evaluation of latest-generation LLMs in phishing contexts with continuous benchmarking as models evolve.

4.2 Absence of Real-World Deployment

Gap: All existing research occurs in controlled laboratory environments. No published studies evaluate AI-generated phishing in actual organizational email systems.

Implications: Laboratory settings differ substantially from real-world contexts where users have rich contextual knowledge, face actual consequences, and process hundreds of emails under time pressure. Real-world effectiveness and false positive rates remain uncertain.

Research Need: Ethical, controlled studies in real organizational environments with appropriate safeguards and IRB oversight.

4.3 Small and Outdated Datasets

Gap: Detection research relies on relatively small datasets (Heiding used 381 emails for detection testing). Datasets become outdated as AI models evolve.

Implications: Small datasets limit model generalization. As Heiding demonstrated, detection models show reduced effectiveness across AI model versions, becoming outdated within months.

Research Need: Large-scale, continuously updated datasets including diverse AI-generated examples from multiple model families, varied target contexts, and regular refreshes.

4.4 Insufficient Psychological Research

Gap: While studies measure click rates and perceived authenticity, deeper psychological mechanisms remain poorly understood.

Implications: Without understanding cognitive processes underlying vulnerability, defensive strategies remain reactive. Questions about which aspects of AI emails trigger trust, what biases are exploited, and how emotional states influence susceptibility remain unanswered.

Research Need: Interdisciplinary research combining cybersecurity, cognitive psychology, and behavioral economics to understand email evaluation processes and develop psychologically-informed interventions.

4.5 Lack of Integrated Defense Research

Gap: Current research examines technical detection and human training in isolation, not as integrated systems.

Implications: Real-world security depends on defense-in-depth combining multiple layers. Understanding how technical and human defenses interact, where redundancies exist, and how to optimally allocate resources requires integrated research.

Research Need: Studies evaluating integrated defense frameworks, hybrid human-AI approaches, and organizational-level interventions.

5. Possible Solutions

5.1 Advanced Machine Learning Detection

Continuous Learning Architectures: Deploy systems that update regularly with new examples rather than remaining static. Heiding's research showed Claude 3.5 Sonnet achieved 97.25% detection with zero false positives when properly configured.

Multi-Modal Analysis: Combine text analysis with sender authentication (SPF, DKIM, DMARC), behavioral patterns, metadata analysis, and link reputation systems.

Explainable AI Detection: Develop models providing interpretable explanations highlighting specific suspicious features, enabling better user education and system refinement.

5.2 Enhanced Human-Centered Defenses

Beyond Generic Training: Move from teaching detection of grammatical errors (now obsolete) to:

- Metacognitive skills recognizing when to shift from automatic to deliberate processing
- Realistic AI-generated phishing examples in training
- Emphasis on verification procedures through separate channels
- Scenario-based training in realistic work contexts

Behavioral Nudges: Redesign interfaces to promote secure behavior:

- Friction for risky actions (delays before clicking unfamiliar links)
- Verification prompts for high-risk content
- Clear visual trust indicators showing authentication status
- Seamless out-of-band confirmation channels

Gamification: Implement regular simulated phishing with immediate educational feedback, progress tracking, and difficulty adaptation based on user performance.

5.3 Organizational Defenses

Communication Authentication: Mandatory SPF, DKIM, DMARC implementation with "reject" policies preventing impersonation.

Incident Response: Easy reporting mechanisms, rapid analysis and response, automated blocking across organizations, and post-incident analysis.

Risk-Based Controls: Adaptive authentication requiring additional verification for high-risk actions, zero-trust architecture, and AI-powered risk assessment.

5.4 Collaborative Solutions

Information Sharing: Industry-wide platforms sharing AI phishing campaign indicators with standardized formats.

AI Provider Responsibilities: Robust content policies, technical controls detecting phishing generation attempts, and safety research investment.

Economic Analysis: Heiding et al. demonstrated AI phishing increases profitability by up to 50 times for larger audiences. Fully automated AI phishing costs approximately \$0.04 per email while achieving expert-level effectiveness, making it economically viable for targeting groups as small as 2,859 individuals (at median conversion rates).

6. Conclusion

The emergence of AI-generated phishing represents a fundamental shift in cybersecurity. Current research unequivocally demonstrates that AI-generated phishing emails perform on par with human experts, achieving 54% click rates compared to 12% for non-personalized control emails. Traditional spam filters achieve only 43% accuracy against AI phishing, while advanced LSTM models reach 87% accuracy and AI-based detection (Claude 3.5) achieves 97.25% with zero false positives.

Critical Gaps Identified:

1. Limited testing of advanced AI models (GPT-4, Claude 3.5, Gemini)
2. Absence of real-world deployment studies
3. Small, outdated detection datasets
4. Insufficient psychological research on vulnerability mechanisms
5. Lack of integrated defense frameworks

Implications for Practice:

Organizations cannot rely on traditional defenses. Comprehensive strategies must integrate:

- Advanced ML detection with continuous learning
- Enhanced human training focusing on verification rather than detection
- Strong organizational authentication and incident response
- Collaborative information sharing

Future Research Directions:

Near-Term (1-2 years):

- Evaluate latest AI models in phishing contexts
- Develop larger, continuously updated datasets
- Conduct psychological research on cognitive vulnerabilities
- Deploy pilot studies in real organizational environments

Medium-Term (2-5 years):

- Create integrated defense frameworks
- Expand multilingual and cross-cultural research
- Develop standardized benchmarks
- Establish policy and regulatory frameworks

Long-Term (5+ years):

- AI-powered adaptive defense systems
- Fundamental authentication advances
- Global cybersecurity coordination
- AI safety integration in model development

Final Perspective:

As demonstrated by Heiding et al., AI phishing capabilities have improved dramatically in just one year, with fully automated systems now matching human expert performance. The democratization of sophisticated attack capabilities means the threat will worsen before improving. However, the same AI capabilities enabling attacks can power defenses. Success depends on layered defenses, rapid adaptation, continuous learning, and organizational resilience. The research community, industry,

policymakers, and society must collaborate to meet this challenge, as protecting trust and communication in an increasingly digital world is a societal imperative.

References

Alharthi, A., et al. (2024). Analysis and Prevention of AI-Based Phishing Email Attacks. *Electronics*, 13(10), 1839. <https://doi.org/10.3390/electronics13101839>

Heiding, F., Lermen, S., Kao, A., Schneier, B., & Vishwanath, A. (2024). Evaluating Large Language Models' Capability to Launch Fully Automated Spear Phishing Campaigns: Validated on Human Subjects. *arXiv preprint arXiv:2412.00586*.